国家标准《网络安全技术 网络安全漏洞分类分级指南》（征求意见稿）编制说明

一、工作简况

1.1 任务来源

根据国家标准化管理委员会2026年下达的国家标准制修订计划,《网络安全技术 网络安全漏洞分类分级指南》由中国信息安全测评中心负责承办,计划号：20260806-T-469。本标准由全国网络安全标准化技术委员会归口管理。

1.2 制定背景

GB/T 30279-2020《信息安全技术 网络安全漏洞分类分级指南》由中国信息安全测评中心牵头修订，于2020年11月发布，2021年6月正式实施后，在我国网络安全领域得到了广泛的应用，为规范和服务漏洞管理、产品生产、技术研发、网络运营等相关活动中进行的漏洞分类和危害等级评估发挥了重要作用。

随着我国网络强国战略的深入推进和信息技术创新能力的显著提升,关键领域的自主可控发展与国产化替代进程加速落地,网络安全漏洞管理领域亟需构建符合国情、适配国产技术生态的分类分级标准体系,摆脱对国外标准体系（如《通用缺陷枚举（CWE）》、《通用漏洞评分系统（CVSS）》）的过度依赖，强化国家关键信息基础设施安全防护的主动性。为更好地适应国际形势变化，进一步提高信息技术产业漏洞管理水平，增强网络强国建设质效，拟从标准的适用性、分类分级指标细化等方面，对本标准进行修订。

1.3 起草单位

本标准由中国信息安全测评中心牵头，参与单位包括中国信息通信研究院、国家信息技术安全研究中心、国家计算机网络应急技术处理协调中心、公安部第一研究所、公安部第三研究所、国家工业信息安全发展研究中心、浙江御安信息技术有限公司、启明星辰信息技术集团股份有限公司、南方电网数字电网集团有限公司网络安全运行调度控制中心、南方电网科学研究院有限责任公司、南方电网数字电网集团信息通信科技有限公司、国网新疆电力有限公司电力科学研究院、中通服咨询设计研究院有限公司、中国移动通信集团有限公司、中国民生银行股份有限公司、杭州安恒信息技术股份有限公司、中兴通讯股份有限公司、华为技

术有限公司、北京神州绿盟科技有限公司、中国联合网络通信集团有限公司、浙江大华技术股份有限公司、北京长亭科技有限公司、天翼安全科技有限公司、北京微步在线科技有限公司、杭州迪普科技股份有限公司、深信服科技股份有限公司、广州市昊恒信息科技有限公司、中国信息安全测评中心华中测评中心、上海斗象信息科技有限公司、北京天融信网络安全技术有限公司、国电南京自动化股份有限公司、中国电子信息产业集团有限公司第六研究所、瀚高基础软件股份有限公司、西安邮电大学、浪潮电子信息产业股份有限公司、中电科金仓（北京）科技股份有限公司、海光信息技术股份有限公司、北京自然原数科技有限公司、浙江鹏信信息科技股份有限公司、亚信科技（成都）有限公司、北京中测安华科技有限公司、中国软件评测中心、国核自仪系统工程有限公司。

本文件主要起草人：杨诗雨、宋创创、刘双喜、姚佳明、马洋洋、司成祥、张增波、宋铮、王诗蕊、封荣、崔牧凡、赵嘉伟、李晔、方硕、郭银锋、买提赛地·买吐送、丁斌、刘欣、毕乐宇、邹洪、李峰、邓萍萍、刘钊、李天磊、廖喜君、夏云浩、吴黎明、张睿、聂晓帆、应天元、杨坤、毛东峰、温佳宝、陈露姹、王振兴、吴文超、魏浩、徐钟豪、王媛媛、刘臻、赵云龙、冯明冉、张勇、张忠伟、宋瑞、展恩果、江晶、艾舒欣、史光庭、康欣元、秦晓磊、杨鑫。

其中：杨诗雨、宋创创、马洋洋负责总体框架，涵盖范围界定、术语定义、章节逻辑连贯性把控及跨组技术协调等工作，确保标准整体结构科学严谨、内容衔接顺畅；刘双喜、姚佳明、封荣、司成祥、崔牧凡、张增波、宋铮、王诗蕊负责漏洞分类和漏洞分级模型研究，并与国际标准对比分析；方硕、丁斌、廖喜君、夏云浩、温佳宝、陈露姹、王振兴、吴文超、徐钟豪、王媛媛负责漏洞分类维度的设计与阐述，包括基于缺陷的漏洞分类和基于影响的漏洞分类两个维度，并进行分类指标体系构建、新兴技术领域漏洞类型的扩展研究，以及分类示例与典型应用场景的说明；赵嘉伟、郭银锋、买提赛地·买吐送、吴黎明、张睿、聂晓帆、江晶、艾舒欣负责漏洞分级模型的建立与完善，包括分级指标的设定与量化、评估模型的构建优化，以及分级方法的应用示例与案例说明；李晔、刘欣、毕乐宇、邹洪、李峰、邓萍萍、刘钊、李天磊、应天元、杨坤、毛东峰、魏浩、刘臻、赵云龙、冯明冉、张勇、张忠伟、宋瑞、展恩果、史光庭、康欣元、秦晓磊、杨鑫负责标准的落地验证与推广应用，包括试点应用方案设计、试点反馈的收集与分

析，以及典型应用案例的总结提炼，为标准的实用性和可操作性提供实践支撑。

1.4 起草过程

标准草案主要工作过程如下：

1）2024 年 10 月，为更好地适应国际形势变化，提高信息技术产业漏洞管理水平，增强网络强国建设质效，提高标准适用性，中国信息安全测评中心在分析国家漏洞库现行标准使用情况、征求网络安全产业界意见、研究国际相关标准和最佳实践的基础上，明确了初步编制思路、制定了标准总体框架并形成了标准草案初稿；

2）2024 年 12 月，在网安标委组织的 2024 年第二次“标准周”上进行了标准修订项目立项汇报，并针对专家意见修订完善草案；

3）2025 年 4 月至 5 月，编写形成国家标准修订项目立项申报相关材料，在网安标委组织的 2025 年第一次“标准周”上进行了标准修订项目立项汇报，并在 2025 年网络安全国家标准立项专家评审会上进行了立项答辩，并根据专家意见修改完善草案；组织召开了国家标准修订项目启动会，联合产学研用相关参与单位 25 家，成立了标准编制组，完善了标准总体框架，明确了标准修订的工作原则、总体规划、技术路线和工作方式，并进行了漏洞缺陷分类、漏洞影响分类和漏洞分级三个方面的任务分工和任务组织；

4）2025 年 6 月至 7 月，进一步调研梳理《通用缺陷枚举（CWE）》、《通用漏洞评分系统（CVSS）》等国内外网络安全漏洞分类分级相关标准及研究成果，分析标准特点，明确标准化需求，与编制组成员研究讨论分类分级指标体系；

5）2025 年 8 月，编制组根据调研成果和参与单位意见对草案进行多轮内容修改和意见征求，形成标准草案第二稿；

6）2025 年 8 月 25 日，全国网络安全标准化技术委员会下发《关于 2025 年 28 项网络安全国家标准项目立项的通知》（网安字〔2025〕15 号），本标准获批立项；

7）2025 年 9 月，秘书处组织网络安全国家标准专家研讨会，WG5 专家组对标准修订项目进行了专家评审，与会专家听取了编制组代表的情况介绍，审阅了标准文本和编制说明，对标准编写思路、编写框架、技术内容、相关标准协调一致性、文本编写规范度等内容进行研讨，并提出专家意见，编制组根据专家意见进一步修订标准文本；编制组召开标准研讨会，与全体编制组成员讨论并明确标

准修订的技术路线、模型方法并征集修订意见，修订完善标准文本形成标准第三稿；

8）2025 年 9 月 15 日，在 2025 年第二次“标准周”上进行草案推进情况汇报，现场听取专家意见并进行答辩，专家组建议形成征求意见稿；

9）2025 年 10 月至 2026 年 4 月，编制组组织工作组会议，根据专家意见与参编单位讨论并修改完善标准文本；编制组参加多次专家评审，并在 2026 年第一次“标准周”上进行征求意见稿汇报，根据专家意见与参编单位多次讨论并修改完善标准文本，形成标准征求意见稿。

二、标准编制原则、主要内容及其确定依据

2.1 标准编制原则

本标准的研究与编制工作遵循以下原则：

（1）通用性原则

本标准在原国标 GB/T30279—2020《信息安全技术 信息安全漏洞分类分级指南》的基础上，结合国内外漏洞分类分级相关领域的最新成果，如国家信息安全漏洞库（CNNVD）、国家信息安全漏洞共享平台（CNVD）、网络安全威胁和漏洞信息共享平台（NVDB）等国家级漏洞库的实践标准，以及《通用缺陷枚举（CWE）》、《通用漏洞评分系统（CVSS4.0）》等国际通用做法，既保证标准编制内容的科学性，又使得标准内容更加符合我国国情。

（2）符合性原则

遵循国家现有漏洞相关法规和标准，符合《网络产品安全漏洞管理规定》等国家有关法律法规和已编制标准规范的相关要求，符合国家漏洞管理主管部门的要求。

（3）可操作性和实用性原则

本标准是对国家级漏洞库实际工作成果的总结与提升，对原国标漏洞分类、分级的结构、形式、规则等进行筛选提炼，保持整体结构合理且维持原意和功能不变，兼容国家级漏洞库，针对不同的用户群体，做到可用、实用、易操作。为此，在本标准的制定过程中，项目组广泛征求用户单位意见，多次组织标准化专家、安全行业专家开展标准研讨，逐条讨论标准适用性、科学性、有效性，确保标准的可操作性和实用性原则。

（4）完备性原则

本标准的完备性原则主要体现在两个方面：其一充分分析了 CWE 的漏洞分类情况和国家漏洞库漏洞分类态势，制定了兼容国际标准且符合中国国情的漏洞分类类型；其二考虑到漏洞分级中涉及的可利用性、影响程度和环境因素，基于原漏洞分级维度的基础上进行分级指标的扩展。因此本标准作为通用性要求可适用于漏洞的分类分级评估。

2.2 主要内容及其确定依据

本标准给出了网络安全漏洞的分类方式、分级指标及分级方法指南。适用于网络产品和服务的提供者、网络运营者、漏洞收录组织、漏洞应急组织在漏洞信息管理、网络产品生产、技术研发、系统运营等相关活动中进行的漏洞分类、漏洞危害等级评估等工作。

2.3 修订前后技术内容的对比

拟修订的主要内容包括：

a) 更改了“网络安全漏洞分类”，某一漏洞可按照需要选择一种或两种漏洞分类维度，也可归为一种或多种漏洞类型（见 5.1，2020 年版的 5.1），旨在解决分类方法对不同使用场景的适配性问题；

b) 增加了“基于影响的漏洞分类”，将原本基于缺陷的单一漏洞类型，拓展为“基于缺陷的漏洞分类”（见 5.2，2020 年版的第 5 章）和“基于影响的漏洞分类”（见 5.3）双重分类框架，旨在解决分类维度对不同使用场景的适配性问题；

c) 增加了“人工智能模型训练推理问题”分类（见 5.2.10），旨在解决漏洞类型对人工智能前沿技术领域的覆盖问题；

d) 更改了“网络安全漏洞分级”，将原标准的技术分级和综合分级修订为两个独立的分级结果（见 6.1、6.3，2020 年版的 6.1、6.3），旨在解决分级方法对不同使用场景的适配性问题；

e) 增加了“攻击复杂度”“间接影响”“潜在损失”“防护能力”等分级指标（见 6.2.1、6.2.2、6.2.3，2020 年版的 6.2.1、6.2.2、6.2.3），旨在解决分级指标对不同使用场景的适配性问题；

f) 增加了“漏洞分类示例”和“漏洞分级示例”（见附录 F、附录 G），旨在解决不同使用对象分类分级操作指引问题；

g） 增加了“漏洞分类兼容性说明”和“漏洞分级兼容性说明”（见附录 H、附录 I），旨在解决标准修订后使用对象在衔接过程中可能存在的适配性问题。

三、试验验证的分析、综述报告，技术经济论证，预期的经济效益、社会效益和生态效益

3.1 试验验证的分析、综述报告

标准参编单位中包含中国信息安全测评中心、中国信息通信研究院、国家信息技术安全研究中心、国家计算机网络应急技术处理协调中心、公安部第一研究所、公安部第三研究所、国家工业信息安全发展研究中心等国家级漏洞库运营机构和网络安全测评机构，以及南方电网科学研究院有限责任公司、中国民生银行股份有限公司等关基用户，华为技术有限公司、浙江大华技术股份有限公司等软硬件厂商，启明星辰信息技术集团股份有限公司、杭州安恒信息技术股份有限公司等安全厂商共同开展标准验证工作。

3.2 技术经济论证

本标准的修订工作充分借鉴了国际通用做法和先进经验，并结合我国网络安全实践进行了大量创新和优化，通过在国家信息安全漏洞库、国家信息安全漏洞共享平台、网络安全威胁和漏洞信息共享平台等国家级漏洞库和行业相关单位进行案例测试和试点验证，能够有效提升漏洞评估的通用性和实用性。

3.3 预期的经济效益、社会效益和生态效益

本标准提出的漏洞缺陷分类、漏洞影响分类和漏洞分级等方面技术要求可有效提升网络产品和服务的提供者、网络运营者、漏洞收录组织、漏洞应急组织在漏洞信息管理、网络产品生产、技术研发、系统运营等相关活动中进行的漏洞分类、漏洞危害等级评估能力，促进网络安全产业生态发展，提升国家整体网络安全防护水平。

四、与国际、国外同类标准技术内容的对比情况，或者与测试的国外样品、样机的有关数据对比情况

本标准基于国家信息安全漏洞库漏洞管理实践经验，充分调研行业应用现状，参考了《通用缺陷枚举（CWE）》、《通用攻击模式枚举和分类（CAPEC）》、《通用漏洞评分系统（CVSS 4.0）》、《利益相关者特定漏洞分类（SSVC）指南》等国

外标准文件，在广泛听取了专家意见和建议的基础上形成的。

五、以国际标准为基础的起草情况，以及是否合规引用或者采用国际国外标准，并说明未采用国际标准的原因

本标准修订过程中参考了《通用缺陷枚举（CWE）》、《通用攻击模式枚举和分类（CAPEC）》、《通用漏洞评分系统（CVSS 4.0）》、《利益相关者特定漏洞分类 (SSVC) 指南》等国外标准文件。

六、与有关法律、行政法规及相关标准的关系

建议本标准推荐性实施。本标准与现行法律、法规以及国家标准不存在冲突与矛盾，与《中华人民共和国网络安全法》、《网络产品安全漏洞管理规定》等合规性要求保持一致，与国家现行漏洞相关标准 GB/T 30276-2020《信息安全技术 信息安全漏洞管理规范》、GB/T 28458-2020《信息安全技术 安全漏洞标识与描述规范》等框架一致、内容协调、互为补充，为规范和服务漏洞管理、产品生产、技术研发、网络运营等相关活动中进行的漏洞分类和危害等级评估提供指导。

七、重大分歧意见的处理经过和依据

编制过程中未出现重大分歧。其他详见意见汇总处理表。本标准编制过程中，如标准编制组内部出现重大意见分歧时，由标准编制组组长组织召开内部调解会解决；如标准编制单位之间出现重大意见分歧，由标准编制承担单位中国信息安全测评中心组织召开参编单位调解会解决。如征求意见过程中，各厂家，特别是各部委意见与标准编制组之间出现重大意见分歧，由全国信息安全标准化技术委员会组织召开协调会解决，并认真听取专家意见进行修改。

八、涉及专利的有关说明

本标准不涉及专利等知识产权问题。

九、实施国家标准的要求，以及组织措施、技术措施、过渡期和实施日期的建议等措施建议

本标准作为国家网络安全漏洞管理标准体系的一部分，与 GB/T 30276-2020《信息安全技术 信息安全漏洞管理规范》、GB/T 28458-2020《信息安全技术 安全漏洞标识与描述规范》等标准规范配合实施。

组织措施：由国家漏洞管理职能部门、国家级漏洞管理平台、社会漏洞管理平台、网络产品提供者、网络系统运营单位和安全技术服务商共同实施。

技术措施：漏洞分级计算工具。

过渡期和实施日期：标准发布后经过半年过渡期正式实施。

本标准发布实施后，建议各相关单位按以下要求执行：

1. 对于历史存量漏洞数据，无需按本标准重新进行漏洞类型和漏洞等级的修订，原评估结果依然有效。

2. 本标准发布实施后新发现或新披露的漏洞，建议按照本标准提供的分类分级方法进行评定。

3. 本标准在制定过程中已充分考虑与现行相关标准的兼容性，可确保与现有漏洞管理平台及相关工作流程平滑衔接，不会对现有漏洞管理工作的连续性造成影响。

十、其他应当说明的事项

我单位已按照公平竞争审查表中各项内容进行了逐项审查，从市场准入与退出、商品要素自由流动、生产经营成本、生产经营行为等方面逐项开展审查，未发现有内容存在排除、限制市场竞争的情形，符合公平竞争要求。

本标准不存在版权问题。

《网络安全技术 网络安全漏洞分类分级指南》标准编制组

2026 年 4 月 6 日